

### **Private Key Management:**

To protect the private key by means:-

- Password protection
- Tokens
- Biometrics
- Smart Cards
- Apart from these, the private key used for digital signing must be destroyed. In contrast, the Private key used for encryption/decryption must be archived.
  - In case of certificate expiration, the user needs to update its key.
  - The CA should maintain history of certificates & keys to prevent any legal problems.

### **The PKIX (Public Key Infrastructure X.509) model:**

- (a) **Registration:**  
In this process the end-entity (subject/user) registers to a CA. Usually this is via an RA.
- (b) **Initialization:**  
Process to verify that the end-entity is talking to the right CA.
- (c) **Certification:**  
In this step, the CA creates a digital certificate for the end-entity and returns it to the end-entity and keeps a copy for its own records.
- (d) **Key-Pair Recovery:**  
Keys used for encryption of some old documents may be required to be recovering data for decrypting. Key archival and recovery services can be provided by a CA.
- (e) **Key Generation:**  
PKIX specifies that the end-entity should be able to generate private-and public-keypairs, or the CA/RA should be able to do this for the end-entity.
- (f) **Key Update:**  
This allows issuing new key pair from old one by the automatic renewal of digital certificates. But there is a provision for issuing digital certificate manually.
- (g) **Cross-certification:**  
In this, each end-entity that are certified by different CAs can cross-verify each other.
- (h) **Revocation:**  
PKIX provides support for the checking of the certificate status in two modes: online or offline.

### **PKIX Architectural Model:**

- **X.509 v3 Certificate & v2 Certificate Revocation List profiles:**  
Lists the use of various options while describing extensions of a digital certificate.
- **Operational Protocol:**  
Defines the underlying protocols that provide the transport mechanism.
- **Management Protocol:**  
Enables exchange of information between the various PKI entities and specifies the structure & details of PKI messages.

➤ **Policy outlines:**

Defines policies for the creation of Certificate Policies & Certificate Practice Statements.

➤ **Timestamp & Data Certification Services:**

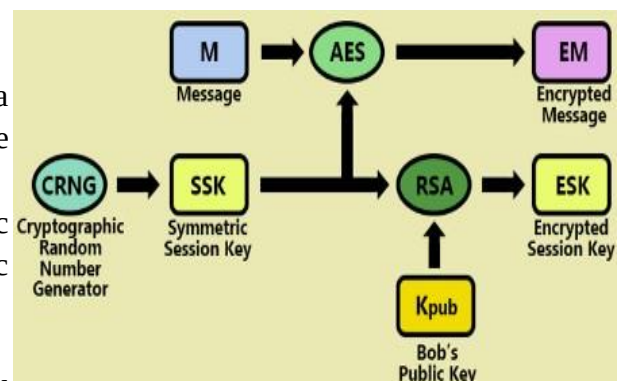
Both are the trusted third parties that provide services to guarantee the existence of certificate & DCS verifies the correctness of data that it receives.

## **PKCS (Public Key Cryptography Standards)**

| <b>Standard</b> | <b>Description</b>                                                                                                      |
|-----------------|-------------------------------------------------------------------------------------------------------------------------|
| PKCS#1:         | RSA Encryption Standard. Defines rules for calculating digital certificate.                                             |
| PKCS#2:         | RSA Encryption Standard for Message Digest.                                                                             |
| PKCS#3:         | Diffie-Hellman Key Agreement Standard.                                                                                  |
| PKCS#4:         | NA. Merged with PKCS#1                                                                                                  |
| PKCS#5:         | Password Based Encryption(PBE). Defines method to encrypt symmetric key.                                                |
| PKCS#6:         | Extended Certificate Syntax Standard. Defines syntax for extending the basic attribute of an X.509 digital certificate. |
| PKCS#7:         | Cryptographic Message Syntax Standard.                                                                                  |
| PKCS#8:         | Private Key Information Standard.                                                                                       |
| PKCS#9:         | Selected Attribute Types. Defines selected attribute for use in PKCS#6 extended certificates.                           |
| PKCS#10:        | Certificate Request Syntax Standard                                                                                     |
| PKCS#11:        | Cryptographic Token Interface Standard.                                                                                 |
| PKCS#12:        | Personal Information Exchange Syntax Standard.                                                                          |
| PKCS#13:        | Elliptic Curve Cryptography Standard.                                                                                   |
| PKCS#14:        | Pseudo –Random Number Generation Standard.                                                                              |
| PKCS#15:        | Cryptographic Token Information Syntax standard.                                                                        |

### **Digital Envelop:**

- A digital envelope is a secure electronic data container that is used to protect a message through encryption and data authentication.
- A Digital Envelope is created by symmetric key algorithm (e.g. AES) and the symmetric key.
- The symmetric key is then encrypted with an asymmetric key algorithm (e.g. RSA) and the recipient's public key.



## CHAPTER-5

### INTERNET SECURITY PROTOCOL

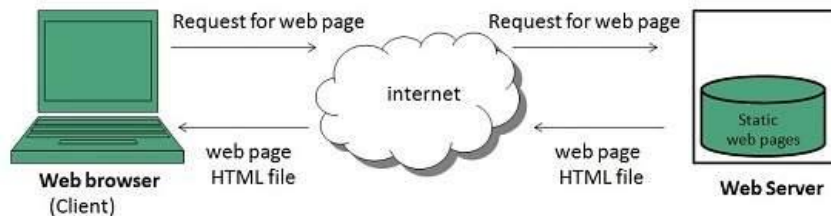
#### Basic concept

In computing, Internet Protocol Security (IPSec) is a secure network protocol suite that authenticates and encrypts the packets of data to provide secure encrypted communication between two computers over an Internet Protocol network. It is used in virtual private networks (VPNs).

#### Static Web page

**Static web pages** are also known as flat or stationary web page. They are loaded on the client's browser as exactly they are stored on the web server. Such web pages contain only static information. User can only read the information but can't do any modification or interact with the information.

Static web pages are created using only HTML. Static web pages are only used when the information is no more required to be modified.



#### Dynamic Web page

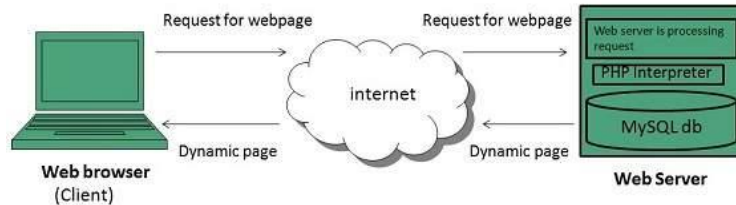
**Dynamic web page** shows different information at different point of time. It is possible to change a portion of a web page without loading the entire web page. It has been made possible using **Ajax** technology.

#### **Server-side dynamic web page**

It is created by using server-side scripting. There are server-side scripting parameters that determine how to assemble a new web page which also includes setting up of more client-side processing.

### Client-side dynamic web page

It is processed using client side scripting such as JavaScript. And then passed in to **Document Object Model (DOM)**.



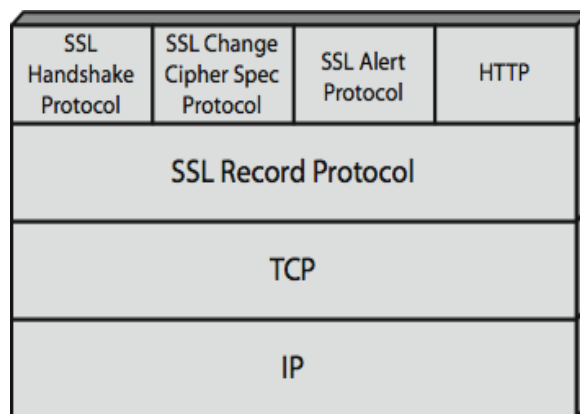
A **static web page** (sometimes called a **flat page** or a **stationary page**) is a web page that is delivered to the user's web browser exactly as stored,<sup>[1]</sup> in contrast to dynamic web pages which are generated by a web application.

Consequently, a static web page displays the same information for all users, from all contexts, subject to modern capabilities of a web server to negotiate content-type or language of the document where such versions are available and the server is configured to do so.

### Secure Socket Layer

- World's most widely used security mechanism on the Internet.
- Secures communication between a client and a server.
- Located between the Application and Transport Layers of TCP/IP protocol suite.

#### SSL Architecture:



SSL is designed to make use of TCP to provide a reliable end-to-end secure service.

SSL is not a single protocol but rather two layers of protocols.

The SSL Record Protocol provides basic security services to various higher-layer protocols.

The HTTP which provides the transfer service for Web client/server interaction, can operate on top of SSL.

SSL consists of three higher-layer protocols:

- Handshake Protocol
- the Change CipherSpec Protocol
- Alert Protocol.

SSL consists of one lower-layer protocols:

SSL Record Protocol

### **SSL Record Protocol Operation:**

The SSL Record Protocol provides two services for SSL connection:

**Confidentiality:** The original data and the MAC are encrypted using secret key cryptography to provide confidentiality.

**Message Integrity:** The Hash function is applied on compressed data to compute a MAC. This provides integrity.

**Fragmentation:** each upper layer message is fragmented into block of 214 bytes (16384bytes) or less.

**Compression:** must be lossless and may not increase the content length by more than 1024 bytes.

**Message Authentication Code:** it is compute a code over the compressed data. For this purpose a shared secret key is used.

Next, the compressed message plus the MAC are encrypted using symmetric encryption.

### **Handshake Protocol:**

This protocol allows the server and client to authenticate each other.

Used to negotiate an encryption and MAC algorithm and cryptographic keys to be used to encrypt data in an SSL record.

In this protocol several msg. are exchanged between client and server.

All of these messages have a fixed format with three fields.

### **Change CipherSpec protocol:**

The cryptographic secret (encrypted data) is generated, once the handshake protocol is over.

It is used to signal that cryptographic secret is ready to use.

This protocol consists of a single message, which consists of a single byte with the value 1.

The sole purpose of this message is to cause the pending state to be copied to into the current state.

### **Alert Protocol:**

The alert protocol is Used to signal errors or any abnormal condition.

Each message in this protocol consists of two bytes.

The first byte takes the value warning(1) or fatal(2) to convey the severity of the Message.

In case of fatal error, the connection is immediately terminated.

## **SECURE HYPER TEXT TRANSFER PROTOCOL (SHTTP)**

- The Secure Hyper Text Transfer Protocol (SHTTP) is a set of security mechanisms defined for protecting the Internet traffic.
- This includes the data-entry forms and Internet-based transactions.
- The services offered by SHTTP are quite similar to those of SSL. However, SSL has become highly successful—SHTTP has not.

- SHTTP works at the application layer, and so it is tightly coupled with HTTP, unlike SSL.
- SHTTP supports both authentication and encryption of HTTP traffic between the client and the server.
- The key difference between SSL and SHTTP is that SHTTP works at the level of individual messages.
- It can encrypt and sign individual messages. On the other hand, SSL does not differentiate between different messages.
- It aims at making the connection between a client and the server, regardless of the messages that they are exchanging.
- Not as popular as SSL
- Almost obsolete.

### **SET (Secure Electronic Transaction):**

- SET is an open encryption and security specification designed to protect credit card transactions on the internet.
- It is developed by VISA and MasterCard for securing credit card transactions over insecure networks, specifically, the internet.
- SET was not itself a payment system. It provides a set of security protocols and formats that enable users to do credit card payment on an open network in secure fashion.
- Merchant does not get to know the credit card details of the cardholder.
- It requires software set up on both client and server.

#### **SET specification:**

- Uses public key cryptography and digital certificates for validating both consumers and merchants.
- It provides the four security requirements – confidentiality, data integrity, user and merchant authentication, and consumer non-repudiation.

#### **Architecture OR participants of SET:**

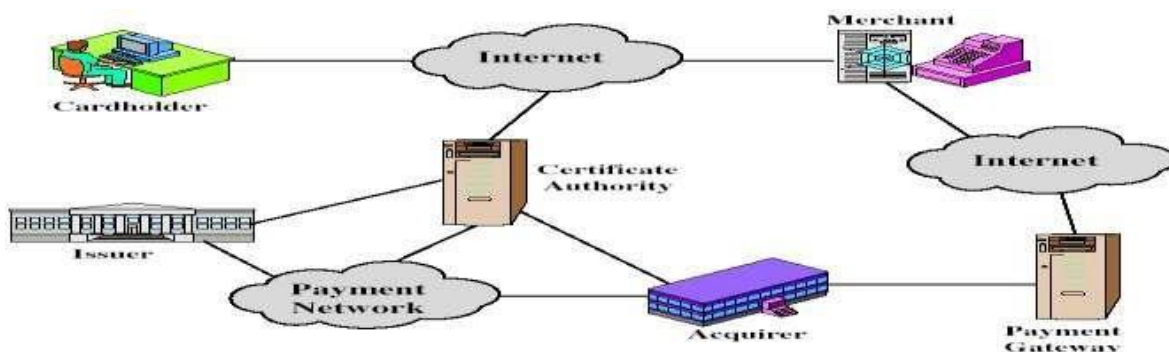
The SET protocol coordinates the activities of:

1. Card Holder (Consumer) – he is the buyer who is the registered holder of the credit card.
2. Card Issuer (Consumer's Bank) – bank that issues the credit card to card holder.
3. Merchant – refers to the seller who is connected to an acquirer.
4. Acquirer (Merchant's Bank) – bank that serves as an agent to link a merchant to multiple issuers (customer's banks).
5. Payment Gateway – this is connected to acquirer. It is situated between the SET system and the financial network of the credit card system for processing the credit card payment.
6. Certification Authority (CA) – Issues digital signatures to concerned parties.

#### **Working/ Process of SET**

Before using SET, both the cardholder and the merchant must register with the CA. After the registration process, the working of SET involves many steps, which are as follows:

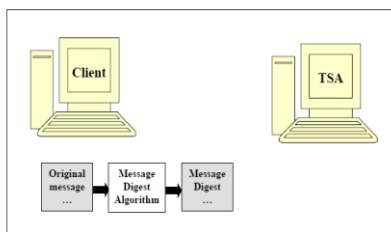
1. The customer browses the merchant's website to evaluate the products offered by the merchant. He or she then selects the products to be purchased and adds them to the shopping cart.
2. The customer then uses a single message to communicate with the merchant and payment gateway. The message has two parts, namely, *purchase order*, which is used by the merchant, and *card information*, which is used by the merchant's bank (acquirer).
3. The card information is then forwarded to the acquirer authorization.
5. If the purchase is authorized, the issuer sends the authorization to the acquirer.
6. A copy of the authorization is also forwarded to the merchant.
7. The merchant completes the order and informs the customer about it.
8. Merchant captures the transaction from its bank.
9. Finally, the credit card invoice is printed by the issuer and provided to the customer.



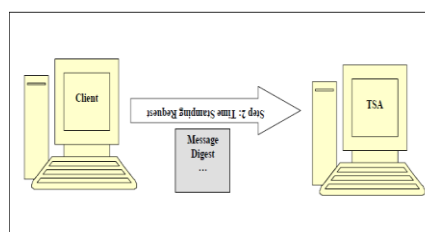
### Time Stamping Protocol (TSP)

- It is a Digital version of a notary service.
- It proves that a document existed at a specific date and time.
- Time Stamping Authority (TSA) is used.

#### Time Stamping Protocol – Step 1



#### Time Stamping Protocol – Step 2



#### Time Stamping Protocol – Step 3

